

МИНИСТЕРСТВО НАУКИ И ВЫСШЕГО ОБРАЗОВАНИЯ РОССИЙСКОЙ ФЕДЕРАЦИИ
ФЕДЕРАЛЬНОЕ ГОСУДАРСТВЕННОЕ АВТОНОМНОЕ ОБРАЗОВАТЕЛЬНОЕ УЧРЕЖДЕНИЕ ВЫСШЕГО ОБРАЗОВАНИЯ
«НАЦИОНАЛЬНЫЙ ИССЛЕДОВАТЕЛЬСКИЙ УНИВЕРСИТЕТ ИТМО»
(Университет ИТМО)

ОТЗЫВ

РУКОВОДИТЕЛЯ УЧЕБНОЙ, ОЗНАКОМИТЕЛЬНОЙ ПРАКТИКИ

Обучающийся	Чу Ван Доан
	(Фамилия, И.О.)
Факультет	Безопасности информационных технологий
Структурное подразделение	ФБИТ
	Группа N3447
Направление (специальность)	10.03.01 Информационной безопасность
Место прохождения практики	Университет ИТМО, ФБИТ
Должность практиканта	Практикант
Тема индивидуального задания	Исследование уязвимостей контроля доступа и разработка методики тестирования в формате Attack-Defense CTF

Оценка достигнутых результатов

№ п/п	Планируемые результаты обучения (показатели)	Оценка			
		5	4	3	2
1.	Понимание формата Attack-Defense CTF: описаны раунды, роль чекера/флагов, статусы OK/MUMBLE/CORRUPT/DOWN и метрика SLA (оформлено в отчёте).	+			
2.	Владение базовыми понятиями контроля доступа: различены аутентификация и авторизация, перечислены типовые модели (RBAC/ownership) и требования к сессиям/cookie.	+			
3.	Развёрнут лабораторный стенд vulnbox в Docker: сервисы запущены, доступность подтверждена (порт(ы), HTTP-ответы/health-check, базовые логи).	+			
4.	Сформирована карта поверхности атаки сервиса: перечислены ключевые эндпоинты, параметры, требования к cookie/сессии, точки проверок прав	+			
5.	Выполнен статический анализ логики доступа: выявлены потенциальные классы ошибок (IDOR, некорректные проверки владения, логические условия, несогласованность проверок).	+			
6.	Разработана методика тестирования контроля доступа: определены критерии pass/fail, типы тестов (positive/negative/edge), порядок фиксации артефактов.	+			
7.	Подготовлена тест-матрица: оформлен набор тест-кейсов (не менее N), с указанием шагов, входных данных, ожидаемого результата и фактического результата.	+			

8.	Проведено тестирование по методике: выполнены сценарии, собраны подтверждения (логи/скриншоты/HTTP-транзакции), оформлена таблица результатов.	+			
9.	Проведён анализ влияния на приватные данные (флаги): описаны риски утечки/подмены данных и связь с CORRUPT/MUMBLE/SLA.	+			
10.	Сформулированы рекомендации по усилению контроля доступа и безопасной работе с сессиями (cookie flags, строгие проверки владения, единые проверки на сервере).	+			
11.	Выполнена валидация рекомендаций: повторно проверены ключевые сценарии, зафиксировано устранение выявленных проблем без ухудшения функциональности.	+			
12.	Подготовлен итоговый отчёт по ГОСТ: структура, выводы, приложения (карта эндпоинтов, тест-матрица, фрагменты логов/результатов эксперимента).	+			
Итоговая оценка					

Руководитель практики _____ Менщиков Александр Алексеевич, к.т.н., доцент ФБИТ
«__» _____ 2026 г.